# Hazard Analysis
# FitFolio

Team #1, Burn n' Earn
Davis Lenover
Preston Grewal
Angad Chhabra
Farid Bastoros
Zaid Alsaadi

Table 1: Revision History

| **Date** | **Developer(s)** | **Change** |
|---|---|---|
| Oct 16, 2026 | Farid Bastoros | Initial revision of 1 Introduction, 3 System Boundaries and Components, 4 Critical Assumptions, 5 Failure Mode and Effect Analysis. |
| Date1 | Name(s) | Description of changes |
| Date2 | Name(s) | Description of changes |
| ... | ... | ... |

# Contents


**1 Introduction** **1**

**2 Scope and Purpose of Hazard Analysis** **1**

**3 System Boundaries and Components** **3**

**4 Critical Assumptions** **6**

**5 Failure Mode and Effect Analysis** **8**
5.1 Method . . . . . 8
5.2 FMEA Table . . . . . 10

**6 Safety and Security Requirements** **15**
6.1 Physical and Psychological Well-being . . . . . 15
6.2 Activity Data Integrity . . . . . 19
6.3 Financial Understanding . . . . . 23
6.4 Market Price and Trade Integrity . . . . . 26
6.5 Privacy and Permissions . . . . . 30
6.6 Social Feed . . . . . 33
6.7 Account Security . . . . . 34
6.8 Traceability Summary . . . . . 37

**7 Roadmap** **39**

**8 Appendix — Generative AI Use Disclosure** **40**
8.1 AI Tools Used . . . . . 40
8.2 How and Where Used . . . . . 40
8.3 Verification of AI-Generated Content . . . . . 40

**9 Appendix — Reflection** **41**

**References** **43**

# List of Figures

1 System boundary of FitFolio. Unshaded boxes are components inside the boundary (dashed line); dark grey boxes are external entities outside it. Each arrow shows that information flows from the element at its tail to the element at its head; a double-headed arrow shows that information flows both ways. The light grey group contains the backend services (C3 to C8): C10 passes each request to the service responsible for it, and every service stores its data in C11. External entity E4 (Network) is not drawn because it carries every arrow that crosses the boundary. E9 (Administrator) is the development team in its operating role (SRS Section 1.3). . . . . 4

# List of Tables

1 Revision History . . . . . i
2 Losses that FitFolio could cause . . . . . 2
3 Components inside the system boundary . . . . . 5
4 External entities outside the system boundary . . . . . 6
5 Severity ratings . . . . . 9
6 Likelihood ratings . . . . . 9
7 Symbolic constants used in the recommended actions . . . . . 10
8 Failure Mode and Effect Analysis of FitFolio . . . . . 11
9 Risk matrix: hazards by severity ($S$) and likelihood ($L$) . . . . . 15
10 Reminder types . . . . . 19
11 Safety and security requirements traceability . . . . . 38

[You are free to modify this template. —SS]

# 1 Introduction

FitFolio is a mobile application in which users earn virtual currency from the physical activity their phone records, invest that currency in a simulated market that follows real-world prices, learn the financial and fitness concepts behind their decisions, and share chosen progress with friends. Although FitFolio controls no physical hardware and never moves real money, it handles health data, presents financial information that users may act on, and rewards physical exertion. Failures in any of these areas can harm users, so a systematic analysis of what can go wrong is needed before the software is designed.

This document identifies the hazards of FitFolio, analyzes how each could arise, and derives requirements that eliminate or reduce them. It uses the following definitions:

- A **hazard** is a state or set of conditions of FitFolio that, together with a set of worst-case conditions in its environment, will lead to a loss [2]. For example, a shared update that reveals a user's weight is a hazard: combined with a friend who sees it, it leads to a loss of privacy.
- A **loss** is harm to a stakeholder that the team wants to prevent. The losses considered in this document are described in Section 2.
- A **failure mode** is a way in which a component of FitFolio can fail to perform its intended function [1]. A component fails not only when its output is missing, but also when its output is wrong, late, or duplicated; this analysis considers all four.
- A **safety or security requirement** is a requirement that eliminates a hazard, reduces its likelihood, or reduces its effects.

The rest of this document is organized as follows. Section 2 states the scope and purpose of the analysis and the losses it aims to prevent. Section 3 defines the system boundary and divides FitFolio into components. Section 4 lists the critical assumptions. Section 5 presents the Failure Mode and Effect Analysis (FMEA), which is the core of this document. Section 6 collects the resulting safety and security requirements, and Section 7 states when each will be implemented.

# 2 Scope and Purpose of Hazard Analysis

FitFolio is designed to change how its users behave: to be more active, to keep up a routine, and to make investing decisions. Features that change behaviour can also cause harm, even when they work as intended. For example, one interview participant described a step streak that now makes them go out walking later

than they should (P01). The purpose of this hazard analysis is to identify how FitFolio could cause harm and to define requirements that control it. Hazards are identified using Failure Mode and Effect Analysis (FMEA) in Section 5, and the resulting safety and security requirements are listed in Section 6 and added to the SRS. The aim is to reduce each risk as low as reasonably practicable (ALARP).

In-app currency has no real-world value, so FitFolio cannot cause a direct financial loss. However, given it is expected to simulate real-world trading it can influence a user's financial choices outside the app. Table 2 lists the losses it can cause. Each requirement in Section 6 names the losses it controls.

Table 2: Losses that FitFolio could cause

| ID | Loss | Description |
|---|---|---|
| L1 | Physical harm | Injury or unsafe exercise, such as exercising while sick or injured or late at night, to earn currency or keep a streak. |
| L2 | Psychological harm | Guilt, anxiety or harm to self-image from missed goals, broken streaks or comparison with friends. |
| L3 | Privacy loss | Health, location, portfolio or social data seen by people the user did not choose, or by third parties. |
| L4 | Security loss | Someone else gaining access to a user's account, or currency earned from fabricated activity. |
| L5 | Data loss and integrity | Lost, duplicated or incorrect activity, currency, holdings or trade records. |
| L6 | Financial-understanding harm | A user learning the wrong lessons about investing, or treating simulated results or in-app content as advice for real financial decisions. |

The analysis covers the FitFolio mobile app on Android and iOS, its server and database, and its use of the phone's health platform and the market data provider. Hazards are considered both when a part fails and when a feature behaves as intended. The following are out of scope:

- The internal workings of the health platforms and the market data provider. How their failures appear in FitFolio, such as missing activity data or delayed prices, is in scope.
- Injuries that are part of a sport or activity itself.
- Stretch goals (Problem Statement Section 3). They will be analysed if they are built.

# 3 System Boundaries and Components

The system analyzed in this document is the software the team builds, configures, and deploys: the FitFolio mobile application, its backend server and the application programming interface (API) through which the app reaches it, its database, and the third-party libraries bundled with them. Third-party libraries are inside the boundary because the team chooses them, controls which version is used, and is responsible for how they are used. Everything FitFolio depends on but does not control is outside the boundary, including the phone's operating system (OS) and health platform, the market data provider, the network, and the hosting service. Hazards that originate outside the boundary are still analyzed when FitFolio must detect or respond to them. For example, FitFolio cannot prevent the market data provider from going offline, but it must not present old prices as current.

The hazards in scope are therefore those that arise in a component inside the boundary, or in an external entity whose failure a component must detect or withstand. They fall into five categories, which match the losses in Section 2 and the groups of requirements in Section 6:

1. **Health and physical safety:** injury, overexertion, or harmful behaviour encouraged by rewards or fitness content.
2. **Privacy and security:** exposure, loss of control, or misuse of personal and health data.
3. **Data integrity:** incorrect balances, rewards, prices, or portfolio values.
4. **Financial learning:** information that misleads users into a wrong understanding or a harmful real-world financial decision.
5. **Availability:** outages or data loss that prevent users from using FitFolio or cost them their progress.

Hazards outside the boundary that FitFolio can neither detect nor influence, such as a defect in the phone's operating system or a breach of the hosting provider's own facilities, are out of scope; they are excluded by the critical assumptions in Section 4.

Figure 1 shows the boundary, the components inside it, and the external entities it depends on. The components are described in Table 3 and the external entities in Table 4. The components are a high-level division for identifying hazards, not a final design; the software architecture will be specified in the Design Document.

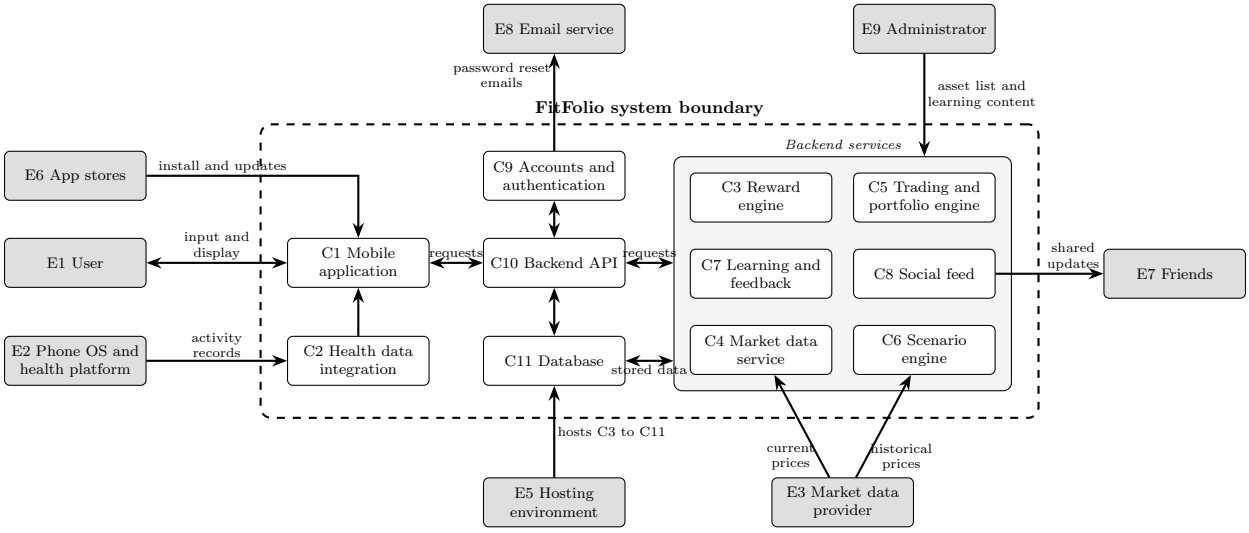



Figure 1: System boundary of FitFolio. Unshaded boxes are components inside the boundary (dashed line); dark grey boxes are external entities outside it. Each arrow shows that information flows from the element at its tail to the element at its head; a double-headed arrow shows that information flows both ways. The light grey group contains the backend services (C3 to C8): C10 passes each request to the service responsible for it, and every service stores its data in C11. External entity E4 (Network) is not drawn because it carries every arrow that crosses the boundary. E9 (Administrator) is the development team in its operating role (SRS Section 1.3).

Table 3: Components inside the system boundary

| **Component** | **Responsibility** | **Sensitive data handled** |
|---|---|---|
| C1 Mobile application | Displays all screens, accepts user input, caches recent data for offline viewing, and stores the user's session on the phone. | Session token, cached balance, portfolio, and activity |
| C2 Health data integration | Requests activity permissions and reads activity records from the health platform through bridge libraries. | Activity records |
| C3 Reward engine | Validates activity records and converts them into rewards. | Activity records, balance |
| C4 Market data service | Retrieves market prices from the provider, caches them, and tracks how old each price is. | None |
| C5 Trading and portfolio engine | Executes trades, maintains holdings and balances, and calculates portfolio value. | Balance, portfolio |
| C6 Scenario engine | Replays historical prices for market scenarios. | Scenario portfolios |
| C7 Learning and feedback | Provides concept explanations and knowledge checks, generates feedback on decisions, and records learning progress. | Learning progress |
| C8 Social feed | Manages friend connections, sharing settings, and shared updates. | Friend list, shared updates |
| C9 Accounts and authentication | Handles sign-up, sign-in, sessions, and account deletion. | Email address, password hash, profile (age, height, weight) |
| C10 Backend API | Receives requests from the mobile application, checks that each is valid and authorized, and passes it to the right component. | All of the above, in transit |
| C11 Database | Stores all persistent data and its backups. | All of the above, at rest |

Table 4: External entities outside the system boundary

| **Entity** | **What crosses the boundary** | **Dependency and why it matters** |
|---|---|---|
| E1 User | Profile, trades, sharing choices, and answers in; balance, portfolio, explanations, and feedback out. | Can make mistakes, misunderstand information, or try to cheat. |
| E2 Phone OS and health platform | Activity records and permission status in. | Data may be missing, wrong, delayed, duplicated, or entered by hand. OS updates can change permissions or break bridge libraries. Use of health data is governed by each platform's policies [3, 4]. |
| E3 Market data provider | Current and historical prices in. | May be unavailable, rate limited, delayed, or wrong. |
| E4 Network | All traffic between C1 and C10, and between C10 and E3. | May be slow, interrupted, or monitored by a third party. |
| E5 Hosting environment | Runs C3 to C11. | May suffer outages or data loss. |
| E6 App stores | The app's installation and updates. | Set privacy and content rules that FitFolio must meet to be distributed [3, 5]. |
| E7 Friends | Shared updates out. | Will see anything that is shared with them, whether or not the user intended it. |
| E8 Email service | The user's email address and a password reset link out. | May be unavailable or delay messages, which stops users from resetting a forgotten password. Must not receive any other personal or health data. |
| E9 Administrator | Changes to the list of tradable assets and to educational content in. | Can make mistakes, such as publishing an incorrect explanation or removing an asset that users hold. |

# 4 Critical Assumptions

The assumptions below are kept to a minimum, because each assumption that removes a hazard also removes it from the analysis. Each assumption states why it is reasonable, which hazards it removes or limits, and what changes if it turns out to be false.

CA1: **No real money.** FitFolio never transfers, holds, or displays real money, and never connects to a bank or brokerage account. *Rationale:* this is

a fixed scope decision in the Problem Statement. *Effect:* hazards of direct monetary loss, such as unauthorized payments, are removed. Indirect financial harm, where a user makes a real-world decision based on misleading information from FitFolio, is still analyzed (H23, H27). *If false:* if in-app purchases or any other real-money feature is added, payment and fraud hazards must be added to this analysis.

CA2: **Users are adults.** FitFolio is intended only for people aged 18 or older. *Rationale:* it is designed for young adults, and collecting health data from minors can require the consent of a parent or guardian under the Personal Information Protection and Electronic Documents Act (PIPEDA) [6]. *Effect:* hazards that apply only to children, such as age-appropriate content, are removed. The hazard that a minor gives a false age is *not* removed and is analyzed (H36). *If false:* if minors are later allowed to use FitFolio, consent, content, and social feed hazards for children must be added to this analysis.

CA3: **Device integrity.** The phone's operating system is not rooted or jailbroken, and it enforces app sandboxing, secure storage, and its permission model as documented. *Rationale:* the team cannot detect or defend against every attack by a compromised operating system. *Effect:* attacks that require control of the operating system are removed. Attacks that use a modified copy of the FitFolio app are still analyzed (H43). *If false:* an attacker in control of the phone could read data stored on it, including the session token. Because rewards, balances, and holdings are calculated only on the server (Section 6), such an attacker could affect only that phone's own account. The app can also detect rooted or jailbroken phones and warn the user, as recommended by the OWASP Mobile Application Security Verification Standard (MASVS) [7].

CA4: **Documented platform behaviour.** When the health platform and market data provider respond, their application programming interfaces behave as their documentation states. *Rationale:* FitFolio depends on these services and cannot verify their internal behaviour. *Effect:* this does not assume the data they return is accurate, complete, or timely; wrong, missing, delayed, and duplicated data are analyzed (H3, H4, H5, H13, H14). *If false:* an undocumented change, such as a renamed field, appears as failed or invalid responses, which FitFolio already handles as missing or wrong data.

CA5: **Hosting security.** The hosting provider protects the physical security of its servers and controls its own staff's access to them. *Rationale:* these controls are outside the team's reach. *Effect:* physical theft from the data centre is removed. Outages, data loss, and breaches through FitFolio's own software or credentials are still analyzed (H40, H44, H45). *If false:* because personal data is encrypted at rest, including in backups (Section 6), stolen storage would not expose it in readable form.

To keep the analysis complete, the following are explicitly *not* assumed, and their failures are included in Section 5:

- The network is always available, fast, or private.
- The market data provider is always available or within its request limits.
- Activity data is accurate, complete, of the correct type and unit, or measured rather than entered by hand.
- The market is open whenever a user wants to trade.
- Users are honest, read every notice, or understand financial terms.
- The phone's clock is correct, or the user stays in one time zone.
- Users enter their true age.
- Third-party libraries are free of defects or remain compatible with new operating system versions.
- Educational content written by the team is free of errors.

# 5 Failure Mode and Effect Analysis

## 5.1 Method

This analysis uses Failure Mode and Effect Analysis (FMEA), following the process described in IEC 60812 [1]. FMEA is a bottom-up method: it examines each component in turn and asks how the component can fail, what the effect of that failure is, and what causes it. The method suits FitFolio because its components (Table 3) are functional units with distinct responsibilities, so working through them one at a time gives systematic coverage. Failures that originate outside the boundary are listed under the component that must detect or respond to them. For each input, the analysis asks what happens if it is missing, wrong, late, or duplicated.

The analysis covers security threats as well as accidental failures. Unlike a hazard, a threat is deliberate, so it cannot be ruled out because it seems unlikely; such failure modes are therefore included even when their causes require an attacker. To check that common hazards were not overlooked, security failure modes were compared with the OWASP Mobile Top 10 [8] and the OWASP Mobile Application Security Verification Standard (MASVS) [7], and accessibility failure modes with the Web Content Accessibility Guidelines (WCAG) [9].

For each failure mode, the recommended action is classified as **elimination** (E), when it removes the failure mode by design, or **mitigation** (M), when the failure mode can still occur but the action reduces its likelihood or its effects. Elimination is preferred wherever it is practical; mitigation is used only where elimination is not possible, following the principle of reducing risk as low as

reasonably practicable (ALARP). Each recommended action leads to one or more safety and security requirements in Section 6, which make the action verifiable.

Each hazard $h$ is rated for severity $S(h)$ (Table 5) and likelihood $L(h)$ (Table 6), each an integer from 1 to 5. Its risk score $R(h)$ and risk class are then

$$R(h) = S(h) \times L(h), \qquad class(h) = \begin{cases} \text{High} & \text{if } S(h) = 5 \text{ or } R(h) \geq 10, \\ \text{Medium} & \text{if } S(h) < 5 \text{ and } 5 \leq R(h) \leq 9, \\ \text{Low} & \text{if } S(h) < 5 \text{ and } R(h) \leq 4. \end{cases} \tag{1}$$

Likelihood ratings are estimates, and an outcome judged "unlikely" still happens. The risk class is therefore used only to order the work in Section 7, never to decide whether a hazard is addressed: every hazard in Table 8 receives a recommended action and a requirement, whatever its class. For the same reason, every hazard of critical severity is classified as High however unlikely it seems. Unlike a risk priority number, the score does not include a detection rating, so a hazard that is easy to detect is not given a lower priority.

Table 5: Severity ratings

| $S$ | **Level** | **Description** |
|---|---|---|
| 1 | Negligible | Minor inconvenience that the user can ignore. |
| 2 | Minor | Frustration, temporary confusion, or incorrect rewards or values that can be corrected without lasting effect. |
| 3 | Moderate | Lost progress, a wrong concept learned, exposure of non-sensitive data, or an outage affecting many users. |
| 4 | Major | Exposure of one user's health or personal data, a real-world financial decision based on misleading information, or injury. |
| 5 | Critical | Exposure of many users' health or personal data, or a threat to a user's physical safety. |

Table 6: Likelihood ratings

| $L$ | **Level** | **Description** |
|---|---|---|
| 1 | Rare | Requires an unusual combination of events. |
| 2 | Unlikely | Could occur, but is not expected during normal use. |
| 3 | Possible | Expected to occur occasionally across all users. |
| 4 | Likely | Expected to occur regularly in normal use. |
| 5 | Almost certain | Expected to occur for most users. |

The recommended actions use three symbolic constants, described in Table 7. Their values are defined once, in Appendix C of the SRS, so the team can adjust a value after testing without changing the actions or requirements that use it.

Table 7: Symbolic constants used in the recommended actions

| Constant | Meaning |
|---|---|
| `QUOTE_STALENESS_LIMIT` | Maximum age of a price used for a trade while the asset's market is open. |
| `SYNC_LOOKBACK_PERIOD` | How far back each sync re-reads activity records, to catch records the health platform writes late. |
| `DATA_DELETION_PERIOD` | Maximum time to delete all of a user's personal data after they delete their account. |

## 5.2 FMEA Table

Table 8 presents the analysis, grouped by component. Its columns are the hazard identifier (ID), failure mode, effects of the failure, causes, detection method, severity ($S$), likelihood ($L$), risk class from Equation (1), type of action (E for elimination, M for mitigation), recommended action, and the resulting safety and security requirements (Req.) in Section 6. Each hazard identifier links to the requirements that address it, and each requirement links back to its hazards.

Table 8: Failure Mode and Effect Analysis of FitFolio

| ID | Failure mode | Effects | Causes | Detection | *S* | *L* | Risk | Type | Recommended action | Req. |
|---|---|---|---|---|---|---|---|---|---|---|
| **C2 Health data integration** | | | | | | | | | | |
| H1 | Activity permission not granted, or revoked | No activity is read, so the user earns nothing and may believe the app is broken | User declines the prompt; OS revokes permission after inactivity or an OS update | Check permission status before every sync | 2 | 4 | Medium | M | Detect the missing permission, explain why it is needed and how to grant it, and keep other features usable | SEC-8, SEC-21 |
| H2 | Health data read without consent, or after consent is withdrawn | Health data used against the user's wishes; breach of PIPEDA's consent principle | Data read before the consent step completes; withdrawal in the app not applied to background reads | Tests that withdraw consent and check that no further reads occur | 4 | 2 | Medium | E | Read health data only after the user consents, and stop every read as soon as consent is withdrawn in the app | SEC-9 |
| H3 | Activity record has the wrong quantity, type, or unit | User is over- or under-rewarded and sees wrong trends | Sensor inaccuracy; activity misclassified (cycling recorded as steps); units mixed (minutes and steps) | Compare each record against plausible limits for its type | 2 | 4 | Medium | M | Reject records outside the plausibility limits for their activity type, and cap daily rewards | SAF-7, SEC-1 |
| H4 | Same activity counted twice | Excess rewards, unfair comparisons with friends, and overstated fitness trends | Phone and connected watch both report the same steps; the same interval is read again on a later sync | Compare record identifiers and overlapping time intervals | 2 | 4 | Medium | E | Reward each interval of activity at most once | SEC-19 |
| H5 | Activity missing or recorded late | User is under-rewarded and sees incorrect trends | OS restricts background sync; phone is off; platform writes data late | Re-read a recent window of records on each sync | 2 | 4 | Medium | M | Re-read and reward activity records from the last `SYNC_LOOKBACK_PERIOD` | SEC-20 |
| H6 | Bridge library fails after an OS update | App crashes or stops reading activity for all users on that OS | Library is unmaintained or not yet updated for a new platform API | Test on each new OS version before release; crash reports | 3 | 3 | Medium | M | Fail without crashing and inform the user; pin library versions and test on new OS versions before each release | SEC-21 |
| H7 | Fabricated activity accepted | Unfair rewards and misleading shared milestones | Manual entries in the health platform; other apps writing data; shaking the phone | Check each record's source; compare against plausible limits | 2 | 3 | Medium | M | Reject records outside the plausibility limits for their activity type, and cap daily rewards | SAF-7, SEC-1 |
| **C3 Reward engine** | | | | | | | | | | |
| H8 | Reward calculated incorrectly | Wrong balance; user loses trust in the app | Wrong conversion rate, rounding error, or mixed units (steps and minutes) | Unit tests with known values; reconcile balance against its history | 2 | 3 | Medium | M | Record every change to a balance with its reason, so the balance can be recomputed and checked | SEC-22 |
| H9 | Activity counted on the wrong day | Daily cap applied to the wrong total; milestones and trends shifted | Time zones, daylight saving changes, or travel | Tests with records near midnight and across time zone changes | 2 | 3 | Medium | E | Assign each record to a day using the user's time zone at the time of the activity | SAF-7, SEC-23 |
| H10 | Rewards encourage overexertion | User exercises beyond safe limits and is injured | Rewards grow without limit; streaks punish rest days; comparison with friends | Not detectable at run time; review reward design against its safety requirements | 4 | 2 | Medium | M | Cap daily rewards, protect streaks with rest days, never take away currency for a lapse, keep goals optional, send reminders only at chosen times, show no rankings, and show a health notice | SAF-1 to SAF-7, SAF-11, SAF-12 |
| H11 | Earning requires attention during exercise | User is distracted, for example near traffic, and has an accident | Features that need a tap, check-in, or timer while exercising | Design review of every earning feature | 4 | 1 | Low | E | Earn currency from recorded activity alone, with no interaction during exercise | SAF-13 |

*Table 8 continued*

| ID | Failure mode | Effects | Causes | Detection | $S$ | $L$ | Risk | Type | Recommended action | Req. |
|---|---|---|---|---|---|---|---|---|---|---|
| H12 | Weight or calories become the focus of rewards | Reinforces harmful eating or exercise behaviour | Rewarding weight change; prominent weight trends; calorie targets | Design review of every reward rule | 4 | 2 | Medium | E | Make body measurements optional and never base rewards on weight or calories | SAF-14 |
| **C4 Market data service** | | | | | | | | | | |
| H13 | Prices not updated | Portfolio value is out of date and trades happen at old prices, teaching wrong lessons | Provider outage, rate limit reached, or expired API key | Track the age of every price | 2 | 4 | Medium | M | Show each price's age and block trades while the market is open and the price is older than `QUOTE_STALENESS_LIMIT` | SEC-2, SEC-3 |
| H14 | Incorrect price used | Wrong portfolio value and misleading feedback | Erroneous data point; wrong symbol mapping; prices in different currencies combined | Compare each new price with the previous one; validate the asset list | 3 | 2 | Medium | M | Store every price with its currency and never combine values in different currencies | SEC-27 |
| H15 | Stock split not applied | Portfolio shows a large false loss or gain | Corporate actions ignored | Split data from the provider; large overnight price changes | 3 | 2 | Medium | E | Adjust holdings and history when a split occurs | SEC-28 |
| H16 | Provider API key exposed | Request quota exhausted, causing an outage for all users, or unexpected cost | Key embedded in the app or committed to the repository | Automated secret scanning on every pull request | 3 | 3 | Medium | E | Keep provider credentials on the server only | SEC-33 |
| **C5 Trading and portfolio engine** | | | | | | | | | | |
| H17 | Trade processed twice | Extra shares bought and balance charged twice | Double tap; app retries after a timeout | Detect repeated request identifiers | 2 | 4 | Medium | E | Process each trade request at most once | SEC-6 |
| H18 | Trade executes at a price different from the one shown | User pays more or receives less than expected and loses trust | Price updated between viewing and confirming | Compare the executed price with the confirmed price | 2 | 4 | Medium | E | Execute at the confirmed price, or ask the user to confirm the new price | SEC-29 |
| H19 | Trade requested while the market is closed | Trade uses an old price, or is blocked with no explanation | Evenings, weekends, and holidays, when most users are free | Check the asset's trading hours before each trade | 2 | 5 | High | E | Queue the trade until the market opens and tell the user | SEC-4 |
| H20 | Balance or holding becomes negative | Invalid portfolio state and incorrect values | Simultaneous requests; missing validation | Database constraints; tests with simultaneous requests | 3 | 2 | Medium | E | Never allow a negative balance or holding | SEC-5 |
| H21 | Trade only partly completed | Currency deducted without shares added, or the reverse | Crash or database error during a trade | Reconcile balances and holdings against trade history | 3 | 2 | Medium | E | Complete each trade fully or not at all | SEC-5 |
| H22 | Portfolio value calculated incorrectly | Wrong progress shown and wrong lessons learned | Floating-point rounding; wrong price used | Tests against hand-calculated values | 3 | 2 | Medium | M | Calculate values to within 0.01 currency units | SEC-30 |
| H23 | User treats simulated results as real financial advice | User makes a real-world investment decision and loses real money | Realistic interface; no clear labelling; feedback worded as a recommendation | Usability testing of labels; content review | 4 | 2 | Medium | M | Label the currency as having no real value and the content as not financial advice; never recommend real-world purchases | SAF-8, SAF-9, SAF-10 |
| **C6 Scenario engine** | | | | | | | | | | |
| H24 | Scenario mistaken for the live market | User believes a crash is happening now, causing anxiety or wrong decisions | Scenario screens look the same as live screens | Usability testing | 3 | 3 | Medium | M | Mark scenario mode clearly and show the historical dates being replayed | SAF-15 |

*Table 8 continued*

| ID | Failure mode | Effects | Causes | Detection | *S* | *L* | Risk | Type | Recommended action | Req. |
|---|---|---|---|---|---|---|---|---|---|---|
| H25 | Scenario trades change the live portfolio | Live progress is corrupted | Shared state between scenario and live portfolios | Tests that run scenarios and check the live portfolio | 3 | 2 | Medium | E | Keep scenario portfolios separate from the live portfolio | SEC-31 |
| H26 | Historical data has gaps | Replay is misleading | Incomplete dataset from the provider | Check datasets for gaps before release | 2 | 2 | Low | E | Validate each scenario dataset before it is offered | SEC-32 |
| **C7 Learning and feedback** | | | | | | | | | | |
| H27 | Educational content is incorrect or outdated | User learns a wrong concept and may apply it to real money or exercise | Author error; rules that change over time, such as contribution limits | Peer review against cited sources | 3 | 3 | Medium | M | Give every content item a source and a review date, and have a second team member review it | SAF-16 |
| H28 | Knowledge check marks an answer incorrectly | User is told a wrong concept is right, or a right one is wrong | Error in the answer key | Peer review of every question and answer | 2 | 3 | Medium | M | Review every answer key with its content item | SAF-16 |
| H29 | Feedback misexplains a portfolio change | User draws the wrong lesson from their own decision | Generic text not based on the user's data; wrong attribution of cause | Tests comparing feedback with known portfolio changes | 2 | 3 | Medium | M | Base feedback on, and show, the user's actual data | SAF-17 |
| H30 | Fitness content read as medical advice | User ignores a medical condition and is harmed | Content worded as personal instructions | Content review | 4 | 2 | Medium | M | Show a health notice and keep fitness content general | SAF-12 |
| **C8 Social feed** | | | | | | | | | | |
| H31 | Update visible beyond the user's choice | Loss of privacy and embarrassment | Sharing on by default; visibility defect; settings reset after an update | Tests of visibility rules for every update type | 4 | 3 | High | M | Share nothing by default and show updates only to accepted friends | SEC-13 |
| H32 | Raw health data or body measurements shared | Loss of privacy about health or body | Shared update built from raw records | Tests of shared update contents | 4 | 2 | Medium | E | Never include raw health data or body measurements in a shared update | SEC-14, SEC-35 |
| H33 | Unwanted contact from other users | Harassment and distress | Anyone can add a user as a friend; no way to remove contacts | User reports | 3 | 2 | Medium | M | Require acceptance of friend requests and allow removing and blocking | SEC-36 |
| H34 | Location revealed through workout data | A user's home or routine is revealed, risking physical safety | Route maps read from workouts | Review of every data type read | 5 | 1 | High | E | Never read or store location or route data | SEC-12, SEC-14 |
| **C9 Accounts and authentication** | | | | | | | | | | |
| H35 | Account taken over | Loss of privacy; account data changed or deleted | Weak or reused passwords; repeated guessing | Monitor failed sign-in attempts | 4 | 3 | High | M | Enforce password rules, limit sign-in attempts, and store session tokens in the phone's secure storage | SEC-38, SEC-39 |
| H36 | A person under 18 creates an account | Health data collected from a minor without the consent the law may require | False age entered at sign-up | Not reliably detectable | 3 | 2 | Medium | M | Require users to confirm they are 18 or older, and delete the account if told otherwise | SEC-37 |
| H37 | Session stays valid after logout or a lost phone | Another person uses the account | Sessions that never expire | Tests of session expiry | 3 | 2 | Medium | M | Expire sessions and allow signing out of all devices | SEC-17 |
| H38 | User cannot sign in | User is locked out of their progress and may abandon the app | Forgotten password; authentication service outage | Monitor sign-in failures and outages | 2 | 3 | Medium | M | Provide password reset by email and show a clear error message when sign-in fails | SEC-40 |
| H39 | Account deletion incomplete | Personal data kept against the user's wishes; breach of PIPEDA | Data left in tables or backups | Tests that delete an account and search for its data | 3 | 2 | Medium | E | Delete all personal data within `DATA_DELETION_PERIOD` of a request | SEC-18 |

*Table 8 continued*

| ID | Failure mode | Effects | Causes | Detection | *S* | *L* | Risk | Type | Recommended action | Req. |
|---|---|---|---|---|---|---|---|---|---|---|
| **C10 Backend API** | | | | | | | | | | |
| H40 | One user can access another user's data | Breach of health and personal data | Missing authorization check on requested records | Tests requesting other users' records | 5 | 2 | High | M | Check on every request that the data belongs to the requesting user | SEC-15 |
| H41 | Data intercepted in transit | Loss of privacy | Unencrypted connection; public Wi-Fi | Configuration tests | 4 | 2 | Medium | M | Encrypt all communication | SEC-16 |
| H42 | Personal data sent to a third party | Health or personal data reaches companies the user never agreed to share it with | Analytics or crash-reporting libraries that send user data; user identifiers added to market data requests | Inspect all outgoing traffic from a test phone and the server | 4 | 2 | Medium | E | Send no personal, health or location data to any third party, and send the market data provider only asset identifiers | SEC-11 |
| H43 | Modified app sends false activity or balances | Unfair rewards and corrupted data | Tampered copy of the app; crafted requests | Server-side validation logs | 2 | 3 | Medium | M | Treat the server as the only authority for rewards and balances, and validate every input | SEC-24, SEC-25 |
| **C11 Database** | | | | | | | | | | |
| H44 | Data lost | Users lose their progress and history | Hosting failure; faulty migration; accidental deletion | Monitoring; scheduled restore tests | 3 | 2 | Medium | M | Back up data at least daily and test restoring it | SEC-26 |
| H45 | Database or backup breached | Health and personal data of all users exposed | Leaked credentials; publicly accessible backups | Access logs | 5 | 2 | High | M | Encrypt data at rest, including backups, and collect only the data the SRS lists | SEC-7, SEC-10, SEC-16 |
| **C1 Mobile application** | | | | | | | | | | |
| H46 | App closed or battery dies during a trade or sync | User cannot tell whether a trade completed, or repeats it | Phone shuts down, user closes the app, or network drops mid-request | Compare the server's record with the app's state when it reopens | 2 | 3 | Medium | E | Complete each trade on the server fully or not at all, and show its final status when the app reopens | SEC-5, SEC-6 |
| H47 | Cached data shown as current while offline | User makes decisions on outdated information | No network; app opened offline | Compare cache time with the current time | 2 | 4 | Medium | M | Show an offline indicator and the time of the last update | SEC-2 |
| H48 | Notification reveals health or portfolio data | Others see private data on the lock screen | Notification text includes values | Review of notification text | 3 | 3 | Medium | M | Keep values out of notifications unless the user turns them on | SEC-34 |
| H49 | Reminder sent at a harmful time | User exercises late at night or while unwell to keep a streak, or is disturbed at work or while asleep | Reminders scheduled without regard to the user's chosen periods; time zone changes | Tests of reminder delivery times, including across time zone changes | 3 | 3 | Medium | M | Send reminders only during the periods the user chose, or the default period if they chose none | SAF-6 |
| H50 | Gains and losses shown by colour alone | Colour-blind users misread their results | Red and green used as the only indicator | Accessibility review | 2 | 3 | Medium | E | Show gains and losses with a sign and text as well as colour | SAF-18 |
| H51 | Phone clock changed to claim rewards | Unfair rewards | User changes the date on the phone | Compare record times with server time | 2 | 2 | Low | E | Use server time and the platform's record times, never the phone clock, for rewards | SEC-24 |

Table 9 summarizes the analysis by placing each hazard of Table 8 at its severity and likelihood; darker cells are higher risk classes. Of the 51 hazards, 21 are eliminated by design and the rest are mitigated. The High-risk hazards concern the exposure of personal data (H31, H35, H40, H45), the user's physical safety (H34), and trading while the market is closed (H19), which is minor but affects almost every user.

Table 9: Risk matrix: hazards by severity ($S$) and likelihood ($L$)

| **Severity** $S$ | **Likelihood** $L$ | | | | |
|---|---|---|---|---|---|
| | **1 Rare** | **2 Unlikely** | **3 Possible** | **4 Likely** | **5 Almost certain** |
| **5** | H34 | H40, H45 | – | – | – |
| **4** | H11 | H2, H10, H12, H23, H30, H32, H41, H42 | H31, H35 | – | – |
| **3** | – | H14, H15, H20, H21, H22, H25, H33, H36, H37, H39, H44 | H6, H16, H24, H27, H48, H49 | – | – |
| **2** | – | H26, H51 | H7, H8, H9, H28, H29, H38, H43, H46, H50 | H1, H3, H4, H5, H13, H17, H18, H47 | H19 |
| **1** | – | – | – | – | – |

# 6 Safety and Security Requirements

The requirements in this section control the hazards identified in the Failure Mode and Effect Analysis (Section 5). Each requirement states what FitFolio shall do, how a tester decides whether it is met (its fit criterion), why it is needed, which hazards and losses it controls, and where it appears in the Software Requirements Specification (SRS). Every requirement except SAF-5 appears in the SRS with the same identifier and wording. SAF-5 applies only if goal suggestions are added. Values written as `SMALL_CAPS` constants are defined in SRS Appendix C. Requirements prefixed SAF address physical, psychological and financial-understanding harm. Requirements prefixed SEC address privacy, security and data integrity. Losses L1–L6 are defined in Table 2.

## 6.1 Physical and Psychological Well-being

**SAF-1 (Rest days protect streaks).** The system shall let the user mark up to `REST_DAYS_PER_PERIOD` days in each `STREAK_PERIOD` as rest days, and a rest day shall not end the user's activity streak.

- **Fit criterion:** A test user with a streak who marks a day as a rest day and records no activity that day does not have the streak reset to zero at the start of the following day. A request to mark more than `REST_DAYS_PER_PERIOD` rest days in one `STREAK_PERIOD` is refused.
- **Rationale:** Streaks reward consistency, which can lead users to exercise while sick, injured or late at night to keep a streak alive. In user interviews, one participant described a step streak that makes them go out walking when they otherwise would not, including late in the evening (P01), and another admired pushing through exercise regardless of pain (P02).
- **Associated hazards:** FMEA H10, L1 (physical harm), L2 (psychological harm).
- **In SRS:** SRS Section 6.2, FR_ActRestDay.
- **Roadmap:** Capstone.

**SAF-2 (No penalty for a lapse).** The system shall not reduce a user's virtual currency balance or simulated holdings when they miss an activity goal or their streak ends, and shall not show a missed goal or an ended streak to other users.

- **Fit criterion:** For a test user who misses their goal on day *d*, the currency balance and simulated holdings at the start of day *d+1* equal those at the end of day *d*. No friend's social feed shows the missed goal or the ended streak.
- **Rationale:** The only consequence of missing a goal is the end of the streak, unless the day is a rest day (SAF-1). Activity recorded on that day still earns currency, as it would with no goal set (SAF-3). Interviews show that keeping a streak going is already a strong motivator (P01). Comparison becomes harmful mainly when a user falls far behind (P02). Taking away earned currency or holdings would also add pressure to exercise when unwell, and would mix fitness penalties into the investment results the user is trying to learn from.
- **Associated hazards:** FMEA H10, L1 (physical harm), L2 (psychological harm), L6 (financial-understanding harm).
- **In SRS:** SRS Section 6.2, FR_ActNoPenalty.
- **Roadmap:** Capstone.

**SAF-3 (Goals are optional).** The system shall not require the user to set an activity goal in order to earn currency for recorded activity.

- **Fit criterion:** A test user with no activity goal set who records activity receives currency for it.

- **Rationale:** Some users track their activity informally and set no goals (P02). Requiring a goal would push them into targets they did not choose, or shut them out of the reward that is central to FitFolio.
- **Associated hazards:** FMEA H10, L1 (physical harm), L2 (psychological harm).
- **In SRS:** SRS Section 6.2, FR_ActGoalOptional.
- **Roadmap:** Capstone.

**SAF-4 (No automatic goal changes).** The system shall not change a user's activity goal without the user's confirmation.

- **Fit criterion:** A test user who exceeds their goal on `GOAL_REVIEW_PERIOD` consecutive days still has the same goal unless they confirm a change.
- **Rationale:** Users fit their goals around their available time and energy. One participant deliberately keeps their step goal fixed, even though they regularly exceed it, because a higher goal takes too much time (P01). Raising goals automatically ignores these limits and leads to overexertion or to goals that are repeatedly missed. Users can still change their own goal at any time (SRS Section 6.2, FR_ActGoal). A change applies from the next day, so lowering a goal cannot keep the current day's streak alive.
- **Associated hazards:** FMEA H10, L1 (physical harm), L2 (psychological harm).
- **In SRS:** SRS Section 6.2, FR_ActNoAutoGoal.
- **Roadmap:** Capstone.

**SAF-5 (Bounded goal suggestions).** The system shall not suggest increasing a user's activity goal by more than `MAX_GOAL_INCREASE` in any one-week period.

- **Fit criterion:** Over any 7-day period, every goal the system suggests to a test user is at most the user's goal at the start of that period multiplied by (1 + `MAX_GOAL_INCREASE`).
- **Rationale:** Large jumps in a goal are not wanted. When raising a challenge, one participant does so only until it is hard but still winnable, and keeps their step goal fixed because a higher target takes too much time (P01). The system therefore limits suggested increases to `MAX_GOAL_INCREASE` per week.
- **Associated hazards:** FMEA H10, L1 (physical harm).
- **In SRS:** None. FitFolio does not suggest goal changes in the capstone.
- **Roadmap:** Future, if goal suggestions are added.

**SAF-6 (Reminders only in chosen periods).** The system shall send reminders of the types in Table 10 only during the time periods the user has chosen to receive them.

- **Fit criterion:** For a test user who has chosen their reminder periods, no reminder of any type in Table 10 is delivered outside those periods. For a test user who has not chosen any periods, reminders are delivered only during `DEFAULT_REMINDER_PERIOD`.
- **Rationale:** A reminder is only useful when the user can act on it. During times such as working hours, a reminder to be active or to check a portfolio cannot be acted on and only interrupts the user. Late reminders also add pressure to exercise late at night: one participant described their streak making them go out walking at 9 p.m. when they otherwise would not (P01). Letting users choose when they are reminded keeps reminders useful and avoids late-night pressure.
- **Associated hazards:** FMEA H10, H49, L1 (physical harm), L2 (psychological harm).
- **In SRS:** SRS Section 6.6, FR_RemindInPeriods. Implemented in part by SRS Section 6.6, FR_RemindPeriods.
- **Roadmap:** Capstone.

**SAF-12 (Health notice before the first reward).** Before the user first earns currency, the system shall display a notice stating that FitFolio does not give medical advice and that users should consult a health professional before starting a new exercise program, and shall not award currency until the user acknowledges it.

- **Fit criterion:** A new test user is shown the notice before their first reward, and earns no currency until they acknowledge it.
- **Rationale:** Rewards encourage more activity, and fitness explanations describe exercise in general terms. A user with a medical condition could read either as a personal recommendation. The notice makes clear that FitFolio is not a substitute for medical advice, and fitness content stays general (SRS Section 1.2, Out of scope).
- **Associated hazards:** FMEA H10, H30, L1 (physical harm).
- **In SRS:** SRS Section 6.2, FR_ActHealthNotice.
- **Roadmap:** Capstone.

**SAF-13 (No interaction during activity).** The system shall award currency for recorded activity without requiring any interaction with FitFolio while the activity is in progress.

- **Fit criterion:** A test user who records a workout without opening FitFolio during it receives the same currency as one who opens the app during the workout.

- **Rationale:** A feature that needs a tap, check-in or timer during exercise draws the user's attention away from their surroundings, for example near traffic. Reading activity from the health platform afterwards (SRS Section 2.5, SC2) removes that need entirely.
- **Associated hazards:** FMEA H11, L1 (physical harm).
- **In SRS:** SRS Section 6.2, FR_ActNoInteraction.
- **Roadmap:** Capstone.

**SAF-14 (No rewards for weight or calories).** The system shall not base any reward, goal or milestone on the user's body weight, change in weight, or calories.

- **Fit criterion:** No reward rule, goal or milestone in FitFolio uses body weight, weight change or calories as an input, and a test user's rewards are unchanged when their weight is changed or removed.
- **Rationale:** Rewarding weight change or calories can reinforce harmful eating and exercise behaviour. Height and weight are optional (SRS Section 6.1, FR_AcctBodyOptional), so no reward can depend on them.
- **Associated hazards:** FMEA H12, L1 (physical harm), L2 (psychological harm).
- **In SRS:** SRS Section 6.2, FR_ActNoWeightReward.
- **Roadmap:** Capstone.

Table 10: Reminder types

| Type | Example | Related feature |
|---|---|---|
| Activity | Progress toward today's goal, or a streak about to end | Activity goals and streaks (SRS Section 6.2) |
| Milestone | A goal reached, or a streak or currency milestone | Milestones and activity trends (SRS Section 6.2) |
| Portfolio | A notable change in simulated portfolio value | Portfolio value (SRS Section 6.3) |
| Learning | A new concept explanation or knowledge check is available | Learning and feedback (SRS Section 6.4) |
| Social | A friend shared an update or sent a friend request | Social feed (SRS Section 6.5) |

## 6.2 Activity Data Integrity

**SAF-7 (Daily earning cap).** The system shall award a user no more than `MAX_DAILY_CURRENCY` virtual currency for recorded activity in any calendar day.

- **Fit criterion:** For a test user whose recorded activity in one calendar day is plausible and would otherwise earn more than `MAX_DAILY_CURRENCY`, the balance increases by exactly `MAX_DAILY_CURRENCY` for that day. Each activity counts toward the calendar day in the user's time zone at the time of the activity.
- **Rationale:** Without a cap, more activity always earns more currency, which rewards exercising past a healthy amount. One participant admired pushing through exercise regardless of pain (P02). A cap also limits what non-exercise motion can earn: phones count steps while riding a bus, and one tracking app was left running for hours after a ride had ended (P01). The cap applies to currency rather than to any one activity, so it works the same way for every supported activity type (Problem Statement Goal 5). The cap limits how much a day can earn, but it does not judge whether an activity record is genuine. SEC-1 covers that.
- **Associated hazards:** FMEA H3, H7, H9, H10, L1 (physical harm), L4 (security loss), L5 (data loss and integrity).
- **In SRS:** SRS Section 6.2, FR_ActDailyCap.
- **Roadmap:** Capstone.

**SEC-1 (Implausible activity earns nothing).** The system shall not count an activity record that exceeds the plausibility limits for its activity type toward the user's currency, activity trends, streak or milestones, and shall show the user that the record was not counted.

- **Fit criterion:** A test record of more than `MAX_DAILY_STEPS` steps in one day, or a workout longer than `MAX_WORKOUT_DURATION`, earns no currency, does not appear in the user's activity trends, streak or milestones, and is shown to the user as not counted.
- **Rationale:** SAF-7 limits how much currency a day can earn, but it does not judge whether a record is genuine. Under the cap alone, a fabricated record still earns the full daily amount. An accidental one, such as a tracking app left running for hours after a ride had ended (P01), also distorts the user's activity trends, which the cap does not touch. This requirement rejects records that could not come from real activity. Small amounts of everyday tracking noise, such as steps counted while riding a bus (P01), stay within the limits and are accepted. The limits target records that are clearly impossible.
- **Associated hazards:** FMEA H3, H7, L4 (security loss), L5 (data loss and integrity).
- **In SRS:** SRS Section 6.2, FR_ActPlausible.
- **Roadmap:** Capstone.

**SEC-19 (Count each activity once).** The system shall award currency for each activity record at most once, even when the record is read more than once.

- **Fit criterion:** When the same test records are read on two consecutive syncs, the user is rewarded for them once.
- **Rationale:** Each sync re-reads recent records to catch late ones (SEC-20). Without this requirement, every re-read would reward the same activity again, over-rewarding the user and overstating their trends and shared milestones. Combining several activity sources is a stretch goal and is out of scope (Section 2).
- **Associated hazards:** FMEA H4, L4 (security loss), L5 (data loss and integrity).
- **In SRS:** SRS Section 7.3, SEC-19.
- **Roadmap:** Capstone.

**SEC-20 (Catch late activity).** On each sync, the system shall read the activity records of the last `SYNC_LOOKBACK_PERIOD` and reward any record that has not already been rewarded.

- **Fit criterion:** A test record written to the health platform two days after the activity took place is rewarded on the next sync, once.
- **Rationale:** The phone's operating system can delay background syncs, and the health platform can receive records late, for example when a watch syncs the next day. Re-reading a recent window catches these records. SEC-19 prevents the re-read records from being counted twice.
- **Associated hazards:** FMEA H5, L5 (data loss and integrity).
- **In SRS:** SRS Section 7.3, SEC-20.
- **Roadmap:** Capstone.

**SEC-21 (Activity unavailable).** When the system cannot read activity data, because permission has not been granted or the health platform does not respond, it shall tell the user that activity could not be read, keep the currency already earned, and keep every feature that does not need new activity data usable.

- **Fit criterion:** With health permission denied, and separately with the health platform returning errors, a test user is told that activity could not be read, their balance is unchanged, and trading, learning and the social feed still work.
- **Rationale:** Permission can be declined or revoked by the operating system, and a library update can break reading for every user on one operating system version. Neither should crash the app or cost the user what they have earned.
- **Associated hazards:** FMEA H1, H6, L5 (data loss and integrity).
- **In SRS:** SRS Section 7.3, SEC-21. Implemented in part by SRS Section 6.2, FR_ActNoData.

- **Roadmap:** Capstone.

**SEC-22 (Balance history).** The system shall record every change to a user's currency balance with its amount, time and reason, and the balance shall always equal the sum of its recorded changes.

- **Fit criterion:** For a test user after a series of rewards and trades, the balance equals the sum of the recorded changes, and each change shows its amount, time and reason.
- **Rationale:** A wrong conversion rate or rounding error in a reward is otherwise invisible. A complete history lets the team detect it, recompute the correct balance, and explain any balance to the user.
- **Associated hazards:** FMEA H8, L5 (data loss and integrity).
- **In SRS:** SRS Section 7.3, SEC-22.
- **Roadmap:** Capstone.

**SEC-23 (Count activity on the user's day).** The system shall assign each activity record to a calendar day using the user's time zone at the time of the activity.

- **Fit criterion:** Test records at 23:30 and 00:30 local time are assigned to two different days, and a record made before a time zone change keeps the day on which it took place.
- **Rationale:** The daily earning cap (SAF-7), streaks and trends all depend on which day a record belongs to. Using the server's time zone, or ignoring travel and daylight saving changes, moves activity to the wrong day.
- **Associated hazards:** FMEA H9, L5 (data loss and integrity).
- **In SRS:** SRS Section 7.3, SEC-23.
- **Roadmap:** Capstone.

**SEC-24 (The server decides rewards and balances).** The system shall calculate rewards, balances and holdings only on the server, using the health platform's record times and the server's clock, and shall not accept these values, or times, from the app.

- **Fit criterion:** A test request from a modified app that reports its own reward, balance or holding is rejected, and changing a test phone's clock does not change the rewards earned.
- **Rationale:** A modified copy of the app, or a phone with its clock moved, can report any value it likes. Critical Assumption CA3 does not exclude a modified app, so the server must be the only authority for values that matter.
- **Associated hazards:** FMEA H43, H51, L4 (security loss), L5 (data loss and integrity).

- **In SRS:** SRS Section 7.3, SEC-24.
- **Roadmap:** Capstone.

**SEC-25 (Validate every request).** The server shall reject any request whose inputs are missing, of the wrong type, or outside the limits stated in the SRS.

- **Fit criterion:** Test requests with a missing field, a value of the wrong type, and a value outside its SRS limit, such as a negative trade quantity, are each rejected with an error and change no data.
- **Rationale:** Crafted requests can bypass every check made in the app. Checking every input on the server stops them from corrupting data or reaching code paths that were never meant to receive them [8].
- **Associated hazards:** FMEA H43, L4 (security loss), L5 (data loss and integrity).
- **In SRS:** SRS Section 7.3, SEC-25.
- **Roadmap:** Capstone.

**SEC-26 (Backups).** The system shall back up all persistent data at least once every `BACKUP_INTERVAL`, and restoring from a backup shall be tested before each release.

- **Fit criterion:** The backup log shows a backup in every `BACKUP_INTERVAL`, and the release checklist shows a successful test restore before each release.
- **Rationale:** A hosting failure, faulty migration or accidental deletion would otherwise lose every user's progress. A backup that has never been restored may not work when it is needed. Backups are encrypted and covered by deletion (SEC-16, SEC-18).
- **Associated hazards:** FMEA H44, L5 (data loss and integrity).
- **In SRS:** SRS Section 7.3, SEC-26.
- **Roadmap:** Capstone.

## 6.3 Financial Understanding

**SAF-8 (Simulation notice before the first trade).** Before the user's first trade, the system shall display a notice stating that the market is simulated, that virtual currency and holdings have no real-world value, and that nothing in FitFolio is financial advice. The system shall not complete the first trade until the user acknowledges the notice.

- **Fit criterion:** A new test user who attempts their first trade is shown the notice and cannot complete the trade until they acknowledge it. The notice contains all three statements: the market is simulated, currency and holdings have no real-world value, and nothing in FitFolio is financial advice.

- **Rationale:** FitFolio teaches investing by letting users practise, and people learn how to act from what they practise: one participant said that formal study did not show them how to act until they had hands-on experience (P02). The lessons a simulation teaches can carry over to real decisions, and a user could mistake simulated results or in-app content for advice on what to do with real money. Users who learn investing on their own also draw on informal sources of mixed quality: one participant learned from online videos and forums, warned that it is easy to end up following the wrong kinds of investing content, and looked for answers tailored to their own situation (P01).
- **Associated hazards:** FMEA H23, L6 (financial-understanding harm).
- **In SRS:** SRS Section 6.3, FR_MktSimNotice.
- **Roadmap:** Capstone.

**SAF-9 (No personalized recommendations).** The system shall not recommend that a user buy or sell a specific asset.

- **Fit criterion:** No screen or notification shown to a test user tells them to buy or sell a named asset, or presents assets as a "recommended pick".
- **Rationale:** Recommending specific assets would be personalized financial advice, which FitFolio is not licensed to give, and users may act on it with real money (P01).
- **Associated hazards:** FMEA H23, L6 (financial-understanding harm).
- **In SRS:** SRS Section 6.3, FR_MktNoRecommend. Implemented in part by SRS Section 6.4, FR_LearnConcentration.
- **Roadmap:** Capstone.

**SAF-10 (Label simulated returns).** The system shall label every displayed return and portfolio value as simulated.

- **Fit criterion:** Every screen that shows a return or portfolio value shows a "Simulated" label next to it.
- **Rationale:** Simulated returns leave out real costs such as fees and taxes, so users could mistake them for results they would get with real money.
- **Associated hazards:** FMEA H23, L6 (financial-understanding harm).
- **In SRS:** SRS Section 6.3, FR_MktLabelReturns.
- **Roadmap:** Capstone.

**SAF-15 (Mark market scenarios).** The system shall mark every screen of a market scenario as a scenario, and shall show the historical dates being replayed.

- **Fit criterion:** Every screen shown during a test scenario carries a scenario label and the dates of the period being replayed, and no screen of the live market does.
- **Rationale:** A replayed crash that looks like the live market could make a user believe it is happening now, causing anxiety or a real-world decision based on old events.
- **Associated hazards:** FMEA H24, L2 (psychological harm), L6 (financial-understanding harm).
- **In SRS:** SRS Section 6.3, FR_MktScenarioLabel.
- **Roadmap:** Capstone.

**SAF-16 (Reviewed learning content).** The system shall show each concept explanation with its source and the date it was last reviewed, and each explanation and knowledge check answer shall be reviewed by a second team member before it is published.

- **Fit criterion:** Every concept explanation shown to a test user has a source and a review date, and the content log shows a second reviewer for every explanation and answer key.
- **Rationale:** An incorrect explanation or answer key teaches a wrong concept that the user may later apply to real money or exercise. Some rules, such as account contribution limits, also change over time, so each item needs a source and a review date.
- **Associated hazards:** FMEA H27, H28, L6 (financial-understanding harm).
- **In SRS:** SRS Section 6.4, FR_LearnReviewed.
- **Roadmap:** Capstone.

**SAF-17 (Feedback shows its basis).** The system shall base all feedback on a portfolio change on the user's own holdings and price changes, and shall show the data it is based on.

- **Fit criterion:** For a test portfolio change, the feedback names the holdings and price changes it refers to, and these match the portfolio's records.
- **Rationale:** Generic feedback, or feedback that names the wrong cause, teaches the wrong lesson from the user's own decision. Showing the data lets the user check the explanation (SRS Section 6.4, FR_LearnValueChange).
- **Associated hazards:** FMEA H29, L6 (financial-understanding harm).

- **In SRS:** SRS Section 6.4, FR_LearnFeedbackBasis.
- **Roadmap:** Capstone.

**SAF-18 (Gains and losses not shown by colour alone).** The system shall show every gain or loss with a sign or a text label, not by colour alone.

- **Fit criterion:** With the display shown in greyscale, a tester can tell every gain from every loss on every screen.
- **Rationale:** Red and green are the colours most often confused by people with colour vision deficiency, so a user could read a loss as a gain. WCAG 2.2 success criterion 1.4.1 forbids using colour as the only means of conveying information [9].
- **Associated hazards:** FMEA H50, L6 (financial-understanding harm).
- **In SRS:** SRS Section 6.3, FR_MktGainLossLabel.
- **Roadmap:** Capstone.

## 6.4 Market Price and Trade Integrity

**SEC-2 (Price freshness).** The system shall display each asset price with the time it was obtained, and shall mark the price as delayed when it is older than `QUOTE_STALENESS_LIMIT`.

- **Fit criterion:** A test price obtained more than `QUOTE_STALENESS_LIMIT` ago is shown with its time and a "Delayed" marker. A price obtained within the limit is shown with its time and no marker.
- **Rationale:** Market data request limits mean prices can lag the real market. A lagging price shown as current misrepresents how the market moved and how a trade performed. The limit matches Problem Statement Goal 4 (prices within 15 minutes of the real market).
- **Associated hazards:** FMEA H13, H47, L5 (data loss and integrity), L6 (financial-understanding harm).
- **In SRS:** SRS Section 6.3, FR_MktPriceAge.
- **Roadmap:** Capstone.

**SEC-3 (No trades on stale prices).** The system shall not execute a trade while the asset's market is open and the asset's price is older than `QUOTE_STALENESS_LIMIT`.

- **Fit criterion:** While a test asset's market is open and its price is older than `QUOTE_STALENESS_LIMIT`, a trade request for it is refused and the user is told the price is out of date. With a price within the limit, the trade proceeds.

- **Rationale:** A trade at an old price misrepresents how the market moved and teaches the wrong lesson. The limit is the same one SEC-2 uses to mark a price as delayed.
- **Associated hazards:** FMEA H13, L5 (data loss and integrity), L6 (financial-understanding harm).
- **In SRS:** SRS Section 6.3, FR_MktNoStaleTrade.
- **Roadmap:** Capstone.

**SEC-4 (Queue trades while the market is closed).** The system shall queue a trade requested while the asset's market is closed, and execute it at the first price obtained after the market next opens.

- **Fit criterion:** A test trade requested while the market is closed is shown to the user as queued, with a notice that it will run at the opening price, and is executed at the first price obtained after the market opens.
- **Rationale:** Many users have time to practise in the evenings and on weekends, when markets are closed. Running those trades at the last closing price would use an old price, and refusing them without explanation would confuse the user.
- **Associated hazards:** FMEA H19, L5 (data loss and integrity), L6 (financial-understanding harm).
- **In SRS:** SRS Section 6.3, FR_MktQueueClosed.
- **Roadmap:** Capstone.

**SEC-5 (Complete or reject trades).** The system shall record each trade completely, updating both the currency balance and the holdings, or not at all. It shall reject a purchase that costs more than the user's currency balance and a sale of more shares than the user holds.

- **Fit criterion:** A test trade interrupted before it completes leaves the balance and holdings unchanged, and a completed trade changes both. A purchase costing more than the balance, or a sale of more shares than are held, is rejected and changes neither.
- **Rationale:** A partly recorded trade could take currency without adding holdings, or the reverse. Allowing a user to spend more than their balance or sell more than they hold would create currency or holdings that were never earned.
- **Associated hazards:** FMEA H20, H21, H46, L5 (data loss and integrity).
- **In SRS:** SRS Section 6.3, FR_MktAtomicTrade.
- **Roadmap:** Capstone.

**SEC-6 (No duplicate trades).** The system shall record a trade only once when the same trade request is submitted more than once.

- **Fit criterion:** When a test user submits a trade and the same request is sent again, for example by retrying after a dropped connection, exactly one trade is recorded.
- **Rationale:** Mobile connections drop, and an app or user may resend a trade that already went through. Recording it twice would change the balance and holdings in a way the user did not intend.
- **Associated hazards:** FMEA H17, H46, L5 (data loss and integrity).
- **In SRS:** SRS Section 6.3, FR_MktNoDuplicate.
- **Roadmap:** Capstone.

**SEC-27 (Prices in one currency).** The system shall store every price with its currency, and shall not combine values in different currencies without converting them.

- **Fit criterion:** For a test portfolio holding assets priced in two different currencies, every stored price has a currency, and the portfolio value equals the sum of the holdings after conversion to one currency.
- **Rationale:** Assets listed on different exchanges, such as in Canada and the United States, are priced in different currencies. Adding their prices without conversion gives a wrong portfolio value and misleading feedback.
- **Associated hazards:** FMEA H14, L5 (data loss and integrity), L6 (financial-understanding harm).
- **In SRS:** SRS Section 7.3, SEC-27.
- **Roadmap:** Capstone.

**SEC-28 (Apply stock splits).** When an asset undergoes a stock split, the system shall adjust users' holdings and the asset's price history so that the split does not change any portfolio value.

- **Fit criterion:** For a test asset that splits 2-for-1, every holding doubles, every historical price halves, and every portfolio value is the same before and after.
- **Rationale:** Ignoring a split shows a large false loss or gain overnight, which teaches the wrong lesson about the asset.
- **Associated hazards:** FMEA H15, L5 (data loss and integrity), L6 (financial-understanding harm).
- **In SRS:** SRS Section 7.3, SEC-28.
- **Roadmap:** Capstone.

**SEC-29 (Trade at the confirmed price).** The system shall execute a trade at the price shown when the user confirmed it. If that price is no longer the latest price, it shall show the user the new price and ask them to confirm again.

- **Fit criterion:** A test trade confirmed at a price that has not changed executes at that price. When the price changes between viewing and confirming, the trade does not execute until the user confirms the new price.
- **Rationale:** Prices update while the user is deciding. Executing at a different price than the one shown charges the user an amount they did not agree to and undermines trust in the simulation (SRS Section 6.3, FR_MktBuy).
- **Associated hazards:** FMEA H18, L5 (data loss and integrity).
- **In SRS:** SRS Section 7.3, SEC-29.
- **Roadmap:** Capstone.

**SEC-30 (Accurate values).** The system shall calculate every displayed balance and portfolio value to within `VALUE_TOLERANCE` of its exact value.

- **Fit criterion:** For test portfolios with hand-calculated values, every displayed balance and portfolio value differs from the hand-calculated value by at most `VALUE_TOLERANCE`.
- **Rationale:** Rounding errors that build up over many trades show users progress they did not make, and break the balance history check (SEC-22).
- **Associated hazards:** FMEA H22, L5 (data loss and integrity), L6 (financial-understanding harm).
- **In SRS:** SRS Section 7.3, SEC-30.
- **Roadmap:** Capstone.

**SEC-31 (Separate scenario portfolios).** The system shall keep each market scenario's portfolio and balance separate from the user's live portfolio and balance.

- **Fit criterion:** After a test user buys and sells in a scenario, their live balance and holdings are unchanged.
- **Rationale:** A scenario is practice. If its trades changed the live portfolio, the user's real progress would be corrupted by a replay of the past.
- **Associated hazards:** FMEA H25, L5 (data loss and integrity).
- **In SRS:** SRS Section 7.3, SEC-31.
- **Roadmap:** Capstone.

**SEC-32 (Complete scenario data).** The system shall offer a market scenario only after its historical data has been checked to contain a price for every asset in it on every trading day of its period.

- **Fit criterion:** The check is run on every scenario dataset before release, and a test dataset with one missing day is not offered.

- **Rationale:** A replay with gaps jumps between prices and misrepresents what happened in the period, which is the lesson the scenario is meant to teach.
- **Associated hazards:** FMEA H26, L6 (financial-understanding harm).
- **In SRS:** SRS Section 7.3, SEC-32.
- **Roadmap:** Capstone.

**SEC-33 (Provider credentials stay on the server).** The system shall store the credentials for every external service only on the server, never in the app or in the code repository.

- **Fit criterion:** Inspection of the app package and an automated scan of the repository find no external service credentials.
- **Rationale:** A key in the app can be extracted from the installed package, and a key in the repository is visible to anyone with access to it. Either lets others use up the market data request limit, causing an outage for every user, or run up costs [7].
- **Associated hazards:** FMEA H16, L4 (security loss).
- **In SRS:** SRS Section 7.3, SEC-33.
- **Roadmap:** Capstone.

## 6.5 Privacy and Permissions

**SEC-7 (Least-privilege health access).** The system shall request read access only to the health data types listed as activity inputs in the SRS data dictionary, and shall not request permission to write to the health platform.

- **Fit criterion:** Every health permission the system requests is a read permission, and its data type appears in the SRS data dictionary as an activity input.
- **Rationale:** Each extra permission is more personal data that could be exposed. One participant said they look for apps that are frugal with the permissions they ask for (P01).
- **Associated hazards:** FMEA H45, L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-7.
- **Roadmap:** Capstone.

**SEC-8 (State the purpose of each permission).** Before requesting each permission, the system shall tell the user which feature uses that data.

- **Fit criterion:** For every permission request, a test user is shown the feature that uses that data before the request appears.

- **Rationale:** Both participants said they are more willing to grant a permission when it is clear why the app is asking (P01, P02). A user who denies a health permission earns nothing for that activity and may believe the app is broken.
- **Associated hazards:** FMEA H1, L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-8. Implemented in part by SRS Section 6.6, FR_SetPermissionList.
- **Roadmap:** Capstone.

**SEC-9 (Consent and withdrawal).** The system shall obtain the user's consent before it first reads their health data, and shall stop reading health data when the user withdraws consent in the app.

- **Fit criterion:** A new test user's health data is not read until they consent. After they withdraw consent in the app, no further health data is read.
- **Rationale:** Canada's Personal Information Protection and Electronic Documents Act (PIPEDA) requires consent to collect personal information and lets people withdraw it. Health data is among the most sensitive data FitFolio handles.
- **Associated hazards:** FMEA H2, L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-9. Implemented in part by SRS Section 6.6, FR_SetWithdrawConsent.
- **Roadmap:** Capstone.

**SEC-10 (Data minimization).** The system shall send activity data from the user's mobile device to its server only as daily totals for each activity type, not as individual activity records.

- **Fit criterion:** The activity data a test phone sends to the server contains only daily totals for each activity type and no individual activity records.
- **Rationale:** Data that never leaves the phone cannot be exposed by a breach of the server. One participant prefers tools that keep their data on their own device rather than in the cloud (P01).
- **Associated hazards:** FMEA H45, L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-10.
- **Roadmap:** Capstone.

**SEC-11 (No data to third parties).** The system shall not send users' personal or health data to any third party, other than a user's email address and password reset link to the email service that delivers it. Requests to the market data provider shall identify assets only by symbol.

- **Fit criterion:** Every outgoing request from a test mobile device and from the server goes to FitFolio's own server, the market data provider or the email service. Requests to the market data provider contain no personal or health data and identify assets only by symbol. Requests to the email service contain no personal or health data other than the user's email address and their password reset link.
- **Rationale:** Participants judge apps by what happens to their data: one chose apps where their data is not sold (P01), and another wants their data kept secure by a reputable company (P02). Password reset by email (SRS Section 6.1, FR_AcctResetPassword) needs an email service, so it receives only the address and the reset link.
- **Associated hazards:** FMEA H42, L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-11.
- **Roadmap:** Capstone.

**SEC-12 (No location data).** The system shall not read or store location or route data.

- **Fit criterion:** The permissions a test build requests include no location permission, and no location or route data is stored on the phone or the server.
- **Rationale:** None of FitFolio's features need location. Location or route data, such as the route maps some workouts store in the health platform, could reveal where a user lives or regularly goes.
- **Associated hazards:** FMEA H34, L1 (physical harm), L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-12.
- **Roadmap:** Capstone.

**SEC-34 (Private notifications).** The system shall not include health data, balances or portfolio values in a notification unless the user has turned this on.

- **Fit criterion:** With default settings, no notification sent to a test phone contains health data, a balance or a portfolio value.
- **Rationale:** Notifications appear on the lock screen, where anyone near the phone can read them.
- **Associated hazards:** FMEA H48, L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-34.
- **Roadmap:** Capstone.

## 6.6 Social Feed

**SEC-13 (Private by default).** The system shall show a user's statistics only to that user until they choose to share them, and shall show a shared update only to the friends the user selected for it. When the user deletes a shared update or removes a friend, the system shall stop showing the affected shared updates to that friend.

- **Fit criterion:** A test user's new statistic is visible to no other user. Once shared with selected friends, it is visible to exactly those friends. After the user deletes the shared update or removes one of those friends, the shared update no longer appears in that friend's social feed.
- **Rationale:** Problem Statement Goal 3 measures success by users controlling who sees each shared statistic. Friends are expected to see only what a user chooses to share (Problem Statement 1.3).
- **Associated hazards:** FMEA H31, L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-13. Implemented in part by SRS Section 6.5, FR_SocialChooseFriends, FR_SocialDeleteUpdate and FR_SocialRemove.
- **Roadmap:** Capstone.

**SEC-14 (No location detail in shared updates).** The system shall not include location, route or the exact time an activity took place in shared updates.

- **Fit criterion:** No shared update shown to a test user's friends contains a location, a route, or the exact time an activity took place.
- **Rationale:** A route or location, especially combined with when an activity happened, can reveal where a user lives, works or regularly goes. One participant pointed out that removing names does not make a person anonymous, because context can reveal who they are (P01).
- **Associated hazards:** FMEA H32, H34, L1 (physical harm), L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-14.
- **Roadmap:** Capstone.

**SAF-11 (No rankings between users).** The system shall not rank users against each other by activity, currency or portfolio performance.

- **Fit criterion:** No screen shown to a test user orders users by activity, currency or portfolio performance, or shows a user's position relative to others.

- **Rationale:** Seeing friends' progress can motivate, but comparison becomes harmful when a user is far behind (P02). A ranking makes that gap explicit and places someone last. Leaderboards are a stretch goal (Problem Statement Section 3). If they are built, they should be opt-in.
- **Associated hazards:** FMEA H10, L2 (psychological harm).
- **In SRS:** SRS Section 6.5, FR_SocialNoRanking.
- **Roadmap:** Capstone. Opt-in leaderboards: Future, with the stretch goal.

**SEC-35 (No body data in shared updates).** The system shall not include body measurements or individual activity records in any shared update.

- **Fit criterion:** No shared update shown to a test user's friends contains the user's age, height, weight, or an individual activity record.
- **Rationale:** Shared updates are summaries the user chose, of the kinds listed in SRS Section 6.5. Body measurements and raw records are more sensitive than the summaries and are never needed to share progress.
- **Associated hazards:** FMEA H32, L3 (privacy loss).
- **In SRS:** SRS Section 6.5, FR_SocialNoBody.
- **Roadmap:** Capstone.

**SEC-36 (Friends only by acceptance).** The system shall make two users friends only after the user who received the friend request accepts it, and shall let either user remove the other at any time.

- **Fit criterion:** Two test users are not friends while a request between them is pending or after it is declined, and stop being friends as soon as either removes the other.
- **Rationale:** If anyone could add a user as a friend, a stranger could see their shared updates or contact them. Removing a friend lets a user end unwanted contact.
- **Associated hazards:** FMEA H33, L2 (psychological harm), L3 (privacy loss).
- **In SRS:** SRS Section 6.5, FR_SocialAccept and FR_SocialRemove.
- **Roadmap:** Capstone.

## 6.7 Account Security

**SEC-15 (Authenticated access only).** The system shall require an authenticated session for every request that reads or changes a user's data, and shall return another user's data, other than their username, only when that user has shared it with the requester.

- **Fit criterion:** A test request without a valid session is rejected. A request for another user's data, other than their username, that was not shared with the requester is rejected, and a request for data that was shared succeeds.
- **Rationale:** Health, portfolio and social data must reach only the account it belongs to or the friends it was shared with. SEC-13 sets what a user shares. Usernames are the exception because friend requests are sent by username (SRS Section 6.5, FR_SocialRequest).
- **Associated hazards:** FMEA H40, L3 (privacy loss), L4 (security loss).
- **In SRS:** SRS Section 7.3, SEC-15.
- **Roadmap:** Capstone.

**SEC-16 (Protect data in transit and at rest).** The system shall encrypt user data in transit between the phone and the server, and when stored on the server, including in backups.

- **Fit criterion:** Inspecting the network traffic between a test phone and the server, the data stored on the server, and its backups shows no readable user data.
- **Rationale:** Data in transit can be intercepted on public networks, and stored data can be exposed if the server or a backup is compromised. Participants want their data kept secure (P02).
- **Associated hazards:** FMEA H41, H45, L3 (privacy loss), L4 (security loss).
- **In SRS:** SRS Section 7.3, SEC-16.
- **Roadmap:** Capstone.

**SEC-17 (Session expiry).** The system shall end a session when the user signs out of it or when it has not been used for `SESSION_TIMEOUT`, after which the user must sign in again.

- **Fit criterion:** A test session is rejected after the user signs out of it, and after it is left unused for longer than `SESSION_TIMEOUT`. In both cases the user must sign in again to continue.
- **Rationale:** A lost or shared phone, or a stolen session, gives access to a user's health and portfolio data for as long as the session stays valid. Ending unused sessions limits that window, and ending a session at sign-out stops a copied session from being reused (SRS Section 6.1, FR_AcctSignOut).
- **Associated hazards:** FMEA H37, L3 (privacy loss), L4 (security loss).
- **In SRS:** SRS Section 7.3, SEC-17.

- **Roadmap:** Capstone.

**SEC-18 (In-app account deletion).** The system shall let the user delete their account from within the app, and shall delete their account details, profile, activity totals, currency balance, holdings, trades, learning progress, shared updates, friend list and friend requests from the server and its backups within `DATA_DELETION_PERIOD` of the request.

- **Fit criterion:** After a test user deletes their account in the app, they can no longer sign in. Within `DATA_DELETION_PERIOD`, neither the server nor its backups hold any of their account details, profile, activity totals, currency balance, holdings, trades, learning progress, shared updates, friend list or friend requests, and none of their shared updates appear in friends' social feeds.
- **Rationale:** PIPEDA lets people withdraw consent and limits keeping personal information longer than it is needed. The Apple App Store also requires apps that let users create an account to offer account deletion within the app (App Store Review Guideline 5.1.1(v)).
- **Associated hazards:** FMEA H39, L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-18. Implemented in part by SRS Section 6.1, FR_AcctDelete.
- **Roadmap:** Capstone.

**SEC-37 (Adult users only).** The system shall not create an account until the user confirms that they are at least `MIN_USER_AGE` years old.

- **Fit criterion:** A test user who does not confirm their age during sign-up has no account created.
- **Rationale:** Critical Assumption CA2 limits FitFolio to adults, because collecting health data from minors would require additional consent. A user can still give a false age, which is why the hazard remains in the FMEA.
- **Associated hazards:** FMEA H36, L3 (privacy loss).
- **In SRS:** SRS Section 6.1, FR_AcctAgeConfirm.
- **Roadmap:** Capstone.

**SEC-38 (Limit sign-in attempts).** The system shall require passwords of at least `MIN_PASSWORD_LENGTH` characters, and after `MAX_FAILED_SIGNINS` failed sign-in attempts on an account shall refuse further attempts on it for `SIGNIN_LOCKOUT_PERIOD`.

- **Fit criterion:** A test password shorter than `MIN_PASSWORD_LENGTH` is refused at sign-up, and after `MAX_FAILED_SIGNINS` wrong passwords even the correct password is refused until `SIGNIN_LOCKOUT_PERIOD` has passed.

- **Rationale:** Short passwords and unlimited guessing are the most common ways an account is taken over. An account holds health and portfolio data, so a takeover is a High-risk hazard.
- **Associated hazards:** FMEA H35, L3 (privacy loss), L4 (security loss).
- **In SRS:** SRS Section 7.3, SEC-38.
- **Roadmap:** Capstone.

**SEC-39 (Protect the session on the phone).** The system shall store the user's session only in the phone's secure storage.

- **Fit criterion:** Inspection of a test phone's app storage finds the session only in the operating system's secure storage.
- **Rationale:** A session stored in ordinary app storage can be copied by another app or from a backup of the phone, giving access to the account without the password [7].
- **Associated hazards:** FMEA H35, L3 (privacy loss), L4 (security loss).
- **In SRS:** SRS Section 7.3, SEC-39.
- **Roadmap:** Capstone.

**SEC-40 (Account recovery).** The system shall let a user who has forgotten their password set a new one through a link sent to their account's email address.

- **Fit criterion:** A test user who requests a reset receives a link at their email address, and after setting a new password can sign in only with the new one.
- **Rationale:** A user who cannot sign in loses access to all their progress and may abandon the app. The link goes only to the account's email address, so recovery does not open a way into someone else's account.
- **Associated hazards:** FMEA H38, L5 (data loss and integrity).
- **In SRS:** SRS Section 6.1, FR_AcctResetPassword.
- **Roadmap:** Capstone.

## 6.8 Traceability Summary

Table 11 summarises each requirement, the hazards it controls, and where it appears in the SRS.

Table 11: Safety and security requirements traceability

| ID | FMEA rows | Losses | SRS | Roadmap |
|---|---|---|---|---|
| SAF-1 | H10 | L1, L2 | FR_ActRestDay | Capstone |
| SAF-2 | H10 | L1, L2, L6 | FR_ActNoPenalty | Capstone |
| SAF-3 | H10 | L1, L2 | FR_ActGoalOptional | Capstone |
| SAF-4 | H10 | L1, L2 | FR_ActNoAutoGoal | Capstone |
| SAF-5 | H10 | L1 | – | Future |
| SAF-6 | H10, H49 | L1, L2 | FR_RemindInPeriods | Capstone |
| SAF-7 | H3, H7, H9, H10 | L1, L4, L5 | FR_ActDailyCap | Capstone |
| SAF-8 | H23 | L6 | FR_MktSimNotice | Capstone |
| SAF-9 | H23 | L6 | FR_MktNoRecommend | Capstone |
| SAF-10 | H23 | L6 | FR_MktLabelReturns | Capstone |
| SAF-11 | H10 | L2 | FR_SocialNoRanking | Capstone |
| SAF-12 | H10, H30 | L1 | FR_ActHealthNotice | Capstone |
| SAF-13 | H11 | L1 | FR_ActNoInteraction | Capstone |
| SAF-14 | H12 | L1, L2 | FR_ActNoWeightReward | Capstone |
| SAF-15 | H24 | L2, L6 | FR_MktScenarioLabel | Capstone |
| SAF-16 | H27, H28 | L6 | FR_LearnReviewed | Capstone |
| SAF-17 | H29 | L6 | FR_LearnFeedbackBasis | Capstone |
| SAF-18 | H50 | L6 | FR_MktGainLossLabel | Capstone |
| SEC-1 | H3, H7 | L4, L5 | FR_ActPlausible | Capstone |
| SEC-2 | H13, H47 | L5, L6 | FR_MktPriceAge | Capstone |
| SEC-3 | H13 | L5, L6 | FR_MktNoStaleTrade | Capstone |
| SEC-4 | H19 | L5, L6 | FR_MktQueueClosed | Capstone |
| SEC-5 | H20, H21, H46 | L5 | FR_MktAtomicTrade | Capstone |
| SEC-6 | H17, H46 | L5 | FR_MktNoDuplicate | Capstone |
| SEC-7 | H45 | L3 | Section 7.3 | Capstone |
| SEC-8 | H1 | L3 | Section 7.3 | Capstone |
| SEC-9 | H2 | L3 | Section 7.3 | Capstone |
| SEC-10 | H45 | L3 | Section 7.3 | Capstone |
| SEC-11 | H42 | L3 | Section 7.3 | Capstone |
| SEC-12 | H34 | L1, L3 | Section 7.3 | Capstone |
| SEC-13 | H31 | L3 | Section 7.3 | Capstone |
| SEC-14 | H32, H34 | L1, L3 | Section 7.3 | Capstone |
| SEC-15 | H40 | L3, L4 | Section 7.3 | Capstone |
| SEC-16 | H41, H45 | L3, L4 | Section 7.3 | Capstone |
| SEC-17 | H37 | L3, L4 | Section 7.3 | Capstone |
| SEC-18 | H39 | L3 | Section 7.3 | Capstone |
| SEC-19 | H4 | L4, L5 | Section 7.3 | Capstone |
| SEC-20 | H5 | L5 | Section 7.3 | Capstone |
| SEC-21 | H1, H6 | L5 | Section 7.3 | Capstone |
| SEC-22 | H8 | L5 | Section 7.3 | Capstone |
| SEC-23 | H9 | L5 | Section 7.3 | Capstone |
| SEC-24 | H43, H51 | L4, L5 | Section 7.3 | Capstone |
| SEC-25 | H43 | L4, L5 | Section 7.3 | Capstone |

*Table 11 continued*

| ID | FMEA rows | Losses | SRS | Roadmap |
|---|---|---|---|---|
| SEC-26 | H44 | L5 | Section 7.3 | Capstone |
| SEC-27 | H14 | L5, L6 | Section 7.3 | Capstone |
| SEC-28 | H15 | L5, L6 | Section 7.3 | Capstone |
| SEC-29 | H18 | L5 | Section 7.3 | Capstone |
| SEC-30 | H22 | L5, L6 | Section 7.3 | Capstone |
| SEC-31 | H25 | L5 | Section 7.3 | Capstone |
| SEC-32 | H26 | L6 | Section 7.3 | Capstone |
| SEC-33 | H16 | L4 | Section 7.3 | Capstone |
| SEC-34 | H48 | L3 | Section 7.3 | Capstone |
| SEC-35 | H32 | L3 | FR_SocialNoBody | Capstone |
| SEC-36 | H33 | L2, L3 | FR_SocialAccept | Capstone |
| SEC-37 | H36 | L3 | FR_AcctAgeConfirm | Capstone |
| SEC-38 | H35 | L3, L4 | Section 7.3 | Capstone |
| SEC-39 | H35 | L3, L4 | Section 7.3 | Capstone |
| SEC-40 | H38 | L5 | FR_AcctResetPassword | Capstone |

# 7 Roadmap

[Which safety requirements will be implemented as part of the capstone timeline? Which requirements will be implemented in the future? —SS]

# 8 Appendix — Generative AI Use Disclosure

[ChatGPT (version 5) was used to brainstorm ideas for the template for this disclose section. —SS]

## 8.1 AI Tools Used

[Give the name of the AI tool(s) used and the version. —SS]

## 8.2 How and Where Used

[Explain what the tool(s) were used for. Examples include: brainstorming, explaining a technical concept, reviewing the document, generating or modifying text, generating or modifying diagrams, identifying errors or omissions or inconsistencies. —SS]

[For each of the uses, identify which parts of the document were affected. —SS]

[You do not need to report every interaction, but you should disclose the uses that materially contributed to your work —SS]

## 8.3 Verification of AI-Generated Content

[

- Describe how the team checked AI-generated or AI-assisted material before including it in the document.
- In particular, verify factual claims, technical assertions, requirements, calculations, references, and other information for which an AI system may produce incorrect or fabricated results.
- **The team is responsible for the accuracy, completeness, consistency, and appropriateness of the submitted document, regardless of whether material was generated by a human or an AI system.**

—SS]

# 9 Appendix — Reflection

[Not required for CAS 741 —SS]

The purpose of reflection questions is to give you a chance to assess your own learning and that of your group as a whole, and to find ways to improve in the future. Reflection is an important part of the learning process. Reflection is also an essential component of a successful software development process.

Reflections are most interesting and useful when they're honest, even if the stories they tell are imperfect. You will be marked based on your depth of thought and analysis, and not based on the content of the reflections themselves. Thus, for full marks we encourage you to answer openly and honestly and to avoid simply writing "what you think the evaluator wants to hear."

Please answer the following questions. Some questions can be answered on the team level, but where appropriate, each team member should write their own response:

1. What went well while writing this deliverable?
2. What pain points did you experience during this deliverable, and how did you resolve them?
3. Which of your listed risks had your team thought of before this deliverable, and which did you think of while doing this deliverable? For the latter ones (ones you thought of while doing the Hazard Analysis), how did they come about?
4. Other than the risk of physical harm (some projects may not have any appreciable risks of this form), list at least 2 other types of risk in software products. Why are they important to consider?

### 2. What pain points did you experience during this deliverable, and how did you resolve them?

**Davis:** The main pain point for me was that the two halves of the analysis were written in parallel and only connected at the end. I wrote the safety and security requirements in Section 6 while Farid wrote the FMEA in Section 5 on his own branch. His FMEA pointed to requirement IDs that did not exist yet, and my requirements had placeholders where their FMEA rows should go, so neither of us could link to the other until we compared our work near the deadline. Design decisions also changed partway through. For example, we first planned to use location data and later dropped it, and I added requirements for trading on out-of-date prices to match Farid's FMEA. Because I inserted these new requirements in the middle of the list, the IDs after them shifted, and references in other members' sections had to be renumbered. We spent the last few days mapping each hazard to its requirements, filling in the traceability table and finding hazards that no requirement covered yet. I resolved this by mapping every requirement to its FMEA rows, completing the traceability

table, and listing the remaining gaps for Farid in my pull request. Next time, I would agree on the ID scheme with the team at the start and only ever add new IDs at the end, and share an early draft of the hazard list and the requirement list so that both sides can link to each other from the beginning.

**Farid:** The pain point I felt most was that my FMEA and Davis's requirements were written as two separate halves. I identified 48 hazards and gave each one a recommended action with its own requirement IDs, while Davis wrote Section 6 with a different ID scheme. When we combined them, his requirements covered only about 20 of my hazards, so many rows in my table led to no requirement at all. Fixing it took longer than writing the table: I mapped every hazard to his requirements, wrote new requirements for the hazards that had none, and added FMEA rows for three of his requirements that had no hazard behind them. Inserting those rows renumbered every hazard, so each reference in the risk matrix, the critical assumptions and Section 6 had to be updated to match. I resolved this by building the Section 6 hazard lists and the traceability table directly from the FMEA, so that the two halves can no longer disagree. This deliverable showed me how easily the link between a hazard and its requirement breaks when the work is split by section. Next time I would split the work by component instead, so that each person writes both the hazards and the requirements for the same part of the system, and I would add new IDs only at the end of a list so existing references never shift.

# References


[1] International Electrotechnical Commission, *IEC 60812:2018 Failure Modes and Effects Analysis (FMEA and FMECA)*, 3rd ed. Geneva, Switzerland: IEC, 2018.

[2] N. G. Leveson, *Engineering a Safer World: Systems Thinking Applied to Safety*. Cambridge, MA, USA: MIT Press, 2011.

[3] Apple Inc., "App Store Review Guidelines," Section 5.1.3, Health and Health Research. [Online]. Available: https://developer.apple.com/app-store/review/guidelines/

[4] Google LLC, "Android Health Permissions: Guidance and FAQs," Play Console Help. [Online]. Available: https://support.google.com/googleplay/android-developer/answer/12991134

[5] Google LLC, "Developer Program Policy," Google Play Policy Center. [Online]. Available: https://play.google/developer-content-policy/

[6] Government of Canada, *Personal Information Protection and Electronic Documents Act*, S.C. 2000, c. 5. [Online]. Available: https://laws-lois.justice.gc.ca/eng/acts/P-8.6/

[7] OWASP Foundation, "Mobile Application Security Verification Standard (MASVS)," version 2.1.0, Jan. 2024. [Online]. Available: https://mas.owasp.org/MASVS/

[8] OWASP Foundation, "OWASP Mobile Top 10," 2024. [Online]. Available: https://owasp.org/www-project-mobile-top-10/

[9] World Wide Web Consortium (W3C), "Web Content Accessibility Guidelines (WCAG) 2.2," W3C Recommendation, Oct. 2023. [Online]. Available: https://www.w3.org/TR/WCAG22/